Kryptografi, Nøkkelhåndtering og PKI

IN2120

Agenda

- “Kort” repetisjon:
  - Kryptografi
  - PKI
  - Se på noen eksamensoppgaver fortløpende
- Egetarbeid

Kryptografi

Kryptografi

"*Vitenskapen om hemmelig skrift med det formål å skjule betydningen av melding*"

Notasjons-konvensjoner:

- M: melding i klartekst
- C: *Chiffertekst*, aka. krypterte meldingen
- k: Nøkkel (key)
- k_priv: privat nøkkel
- k_pub: offentlig nøkkel
- E: krypteringsalgoritme (encrypt)
- D: dekrypteringsalgoritme (decrypt)

Styrken avhenger av mange ting, men mest av alt:

- Styrken av algoritmen
- Nøkkeløstørrelse

Analogi: sykkellåser

- Nøkkel eller kode?
- Styrke av materiale?



Poenget?

Det er kanskje litt nice med hemmeligheter?

- Vil helst ha det hemmelig for **alle,** eller for alle andre **enn mottagere.**
- Brukes også for å verifiesere

Fokuset er alltid på meldinger, men det brukes også på:

- nettverkstrafikk
- databaser
- data, som helseopplysninger (PII), bilder etc
- Signaturerer

Målet som oftest er å støtte opp:

- Konfidensialitet
- Integritet
- Ubenektlighet

NB!

- Kryptografi er feltet, kryptering og hashing er underkategorier.

- Norsk: krypto, kryptering
- Engelsk: crypto, encryption

Symmetrisk Kryptografi

Symmetrisk Krypto

Egenskap: Nøkkel brukes for både kryptering og dekryptering

Notasjon:

- Kryptering E=(M,k)
- Dekryptering: M = D(C,k)

Pros

- Effektiv på store datasett
- Rask
- Enkel

Cons

- Nøkkeldistribuering
- Ikke ubenektlig
- Kanskje litt mange nøkler?
  - 2:1 nøkkel
  - 100: 4950 nøkler

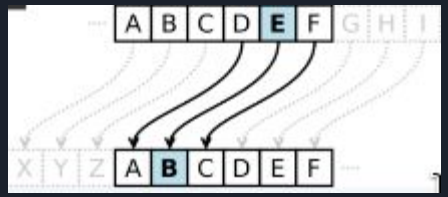
Krypto: Ganske gammelt

Vært en ting **lenge**

Ett av de første eksemplene på dette er Caesar-chiffer.

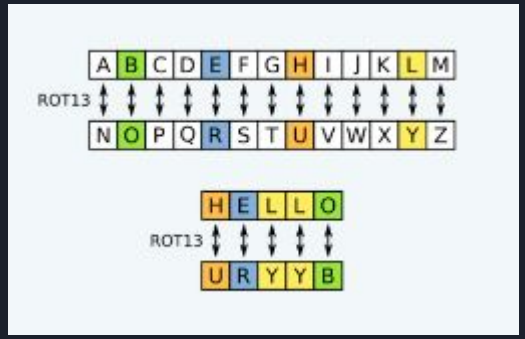
Oppkalt etter Julius Caesar:

- Skifte alfabetet (3 bokstaver var vanlig da)



Annet eksempel er ROT-13:

- 13 bokstaver lenger bak i alfabetet



Blokkchiffer

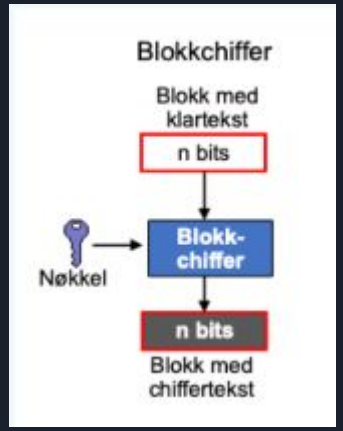
Krypter en blokk med bits med samme nøkkel:

Eksempler på sikre:

- CTR
- CBC
- OFB
- CFB

Usikre:

- ECB



AES er det mest brukte blokkchifferet nå til dags. Har forskjellige moduser.

Brukes i

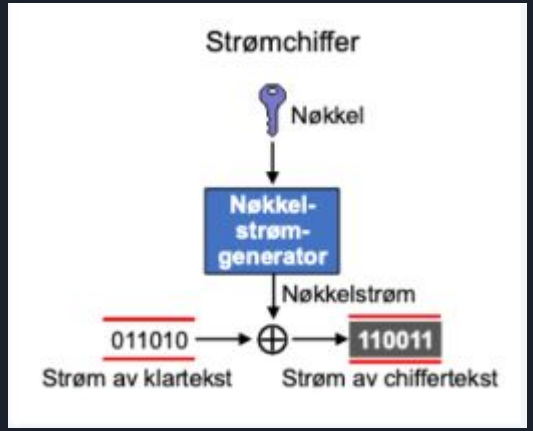
- TLS/SSL
- VPNer
- DIsk og database kryptering
- Alt med data, basically

Strømchiffer

Krypter en *strøm* av data; *bit for bit*.

Brukes også som regel i kommunikasjon, men mest vanlig ved trafikk i mobilkommunikasjon

Det som er mest eksamensrelevant er å vite



Hashing

Hashing != Kryptering != enkoding

En hashingfunksjon skal være:

- deterministisk
- lett å beregne enveis
- fast størrelse
- *kollisjonsresistent*
    - All input skal føre til unik output

Eksempler på algoritmer:

- **MD5** og **SHA-1** er svake
- SHA-2, 3, 256, 512, etc

Hasjkollisjoner

Hashing *skal* gjøre om data på en slik måte at det ikke kan reverseres.

- Også kalt: ***pre-image resistant/one way property***
- Poenget er ikke at man skulle vite hva original teksten er

Brukes til å:

- Lagre passord (kan ikke reverseres: konfidensialitet og integritet)
- Finne ut om dataen har blitt påvirket (integritet)

MAC

Message authentication Code

En felles hemmelig nøkkel brukes sammen med en hash av en annen melding for å sjekke at meldingen ikke har blitt endret på

MAC = Hash(M,k)

Oppnår ikke ubenektighet. Nøkkelen er enten offentlig, eller distribuert av onsinnende.

- Derfor har vi Digital Signatur

2.1 Symmetric Encryption

Mark the statements about **AES** that are true.
Points: 1 for each correct, -1 for each wrong, 0 for no selection, max 2 total
Select one or more alternatives:

- ☐ AES can be used with 2 different keys: one for encrypting and one for decrypting.
- ☐ AES can be used with different key sizes.
- ☐ AES can only encrypt messages up to the block size.
- ☐ AES can be used in different modes, which have different security properties.

Maximum marks: 2

Asymmetrisk Krypto

Asymmetrisk kryptografi

Symmetrisk funker bra når man har en sikker kanal å distribuere dem på. Dette kunne vært fysisk leveranse.

IT beveger seg raskt, det er mer globalisert og har behov for flere garantier (visshet). Derfor har **asymmetrisk** kryptografi utviklet seg fram.

Egenskap: Egen private og offentlige nøkkel

Avsender krypterer en melding med mottakers offentlige nøkkel <-> mottaker dekrypterer chifferet med sin egen private nøkkel

Kjente algoritmer

Tradisjonelle krypteringsalgoritmer

Utrolig matematiske, ikke pensum å vite matten! Bare vit at de funker, fordi vi har problemer i matte som ikke er løst

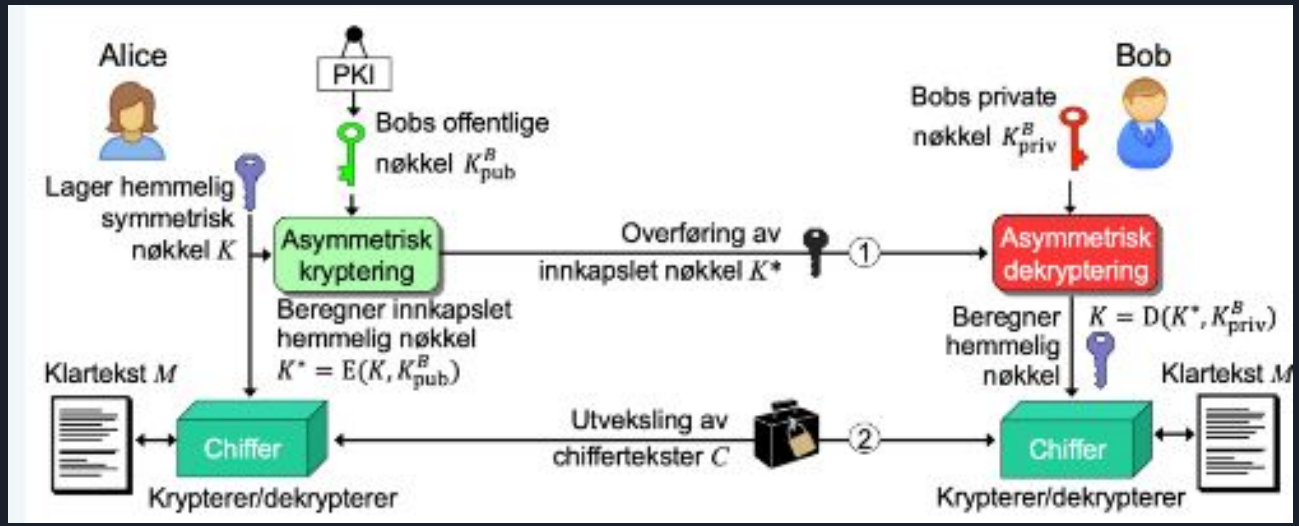
- RSA (integer factorization)
- Elliptisk kurvekryptografi (discrete logarithm problem)
  - Nøkkelstørrelse har lite å si

Lenge anerkjent som de tryggeste av de trygge, men QC har gjort mange av dem foreldet.

- med få unntak

Hybrid kryptering - nøkkeltransport

I *praksis / virkeligheten* bruker vi en blanding av **symmetrisk** og **asymmetrisk**.



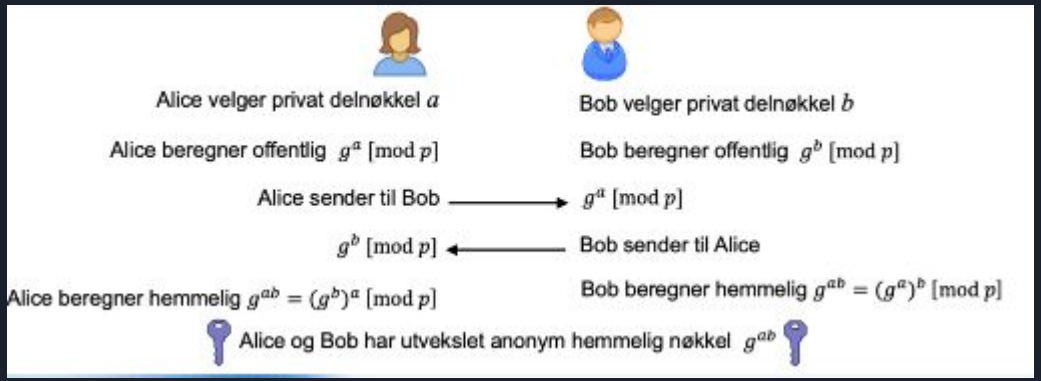
Hva skjer om priv_K til Bob blir funnet ut av?

Diffie-Hellman

Ikke en krypteringsalgoritme! - nøkkelutveksling

Brukes til å opprette øktnøkler

- Manglende autentisering -> Man-in-the-middle angrep



2.4 Diffie-Hellman

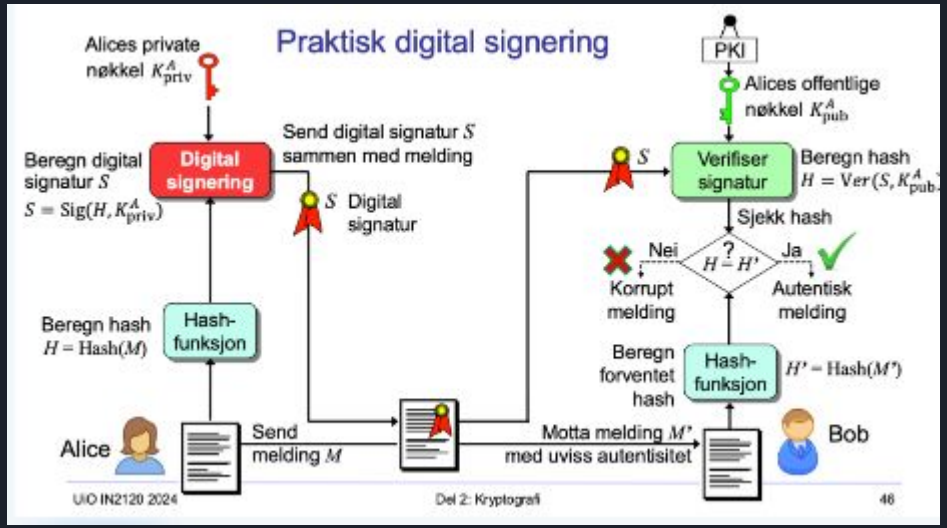
Angi 3 korrekte utsagn om Diffie-Hellman-algoritmen.
Poeng: 1 for hver korrekt, -1 for hver feil, maks 3, minimum 0.
Velg 3 alternativer

- [ ] Brukes for å etablere/utveksle symmetriske nøkler.
- [ ] Brukes til å krypere.
- [ ] Kan potensielt knekkes med kvantecomputere.
- [ ] Brukes for å etablere/utveksle asymmetriske nøkler.
- [ ] Støtter ikke autentisering.
- [ ] Regnes ikke lenger som sikker.

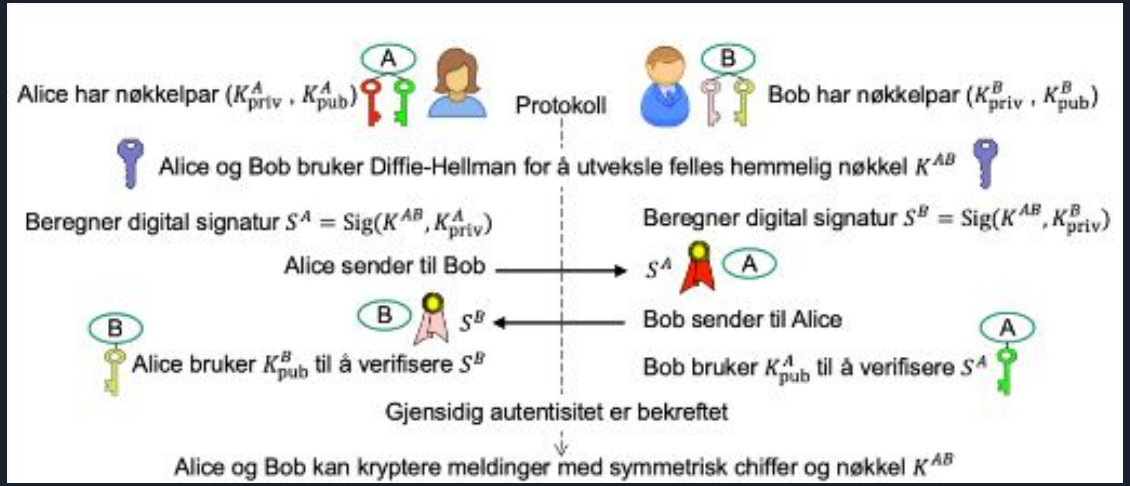
Digital signatur

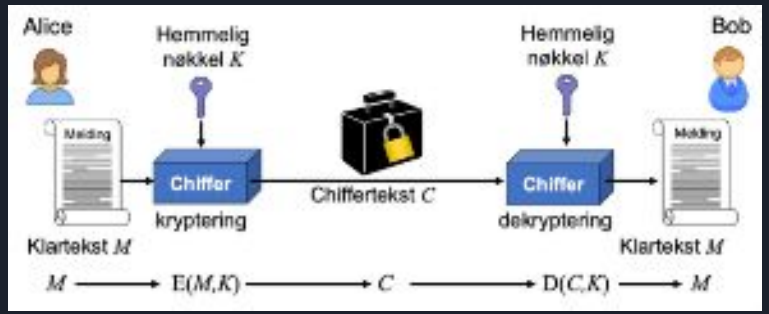
Videreuvikling av MAC

Signatur lages ved å bruke sin egen private nøkkel, siden *ingen andre* har den.



DH + Dig.Sig


Alice har nøkkelpar (K^A_{priv}, K^A_{pub})
A
Protokoll
B
Bob har nøkkelpar (K^B_{priv}, K^B_{pub})
Alice og Bob bruker Diffie-Hellman for å utveksle felles hemmelig nøkkel K^{AB}
Beregner digital signatur $S^A = Sig(K^{AB}, K^A_{priv})$
Beregner digital signatur $S^B = Sig(K^{AB}, K^B_{priv})$
Alice sender til Bob
S^A
Bob sender til Alice
S^B
Alice bruker K^B_{pub} til å verifisere S^B
Bob bruker K^A_{pub} til å verifisere S^A
Gjensidig autentisitet er bekreftet
Alice og Bob kan kryptere meldinger med symmetrisk chiffer og nøkkel K^{AB}


Alice
Hemmelig nøkkel K
Melding
Chiffer
kryptering
Klartekst M
Chiffertekst C
Hemmelig nøkkel K
Chiffer
dekryptering
Bob
Melding
Klartekst M
M → E(M,K) → C → D(C,K) → M

MAC + Digital Signature

Please select for each property, if it applies to **Message Authentication Codes** (MAC), **Digital Signature** (DSig), both (MAC + DSig) or none of these two.
Points: 0.5 for each correct, -0.5 for each wrong, 0 for no selection, max 3 total score

Please match the values:

	MAC	DSig	Both	None
It ensure confidentiality of the message.	○	○	○	○
It ensures integrity of the message.	○	○	○	○
It ensures non-repudiation of the message.	○	○	○	○
Only the recipient (and the sender) can authenticate the message origin.	○	○	○	○
The implementation is based on hash functions.	○	○	○	○
Any party can authenticate the message origin.	○	○	○	○

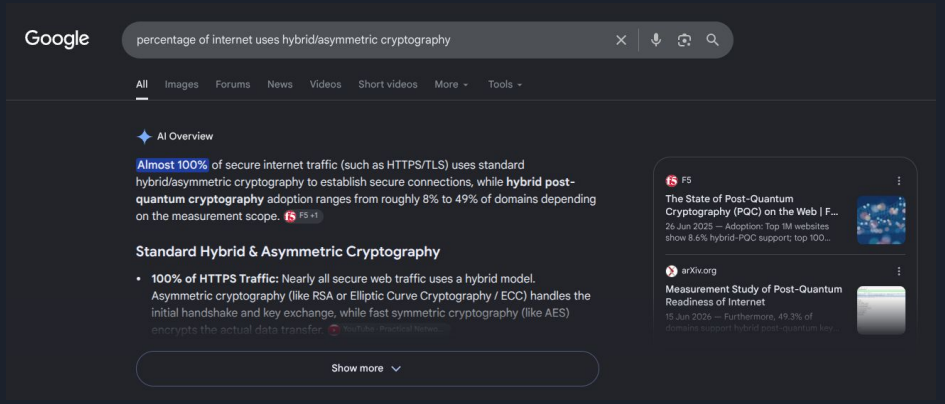
Maximum marks: 3

Post-Kvantekrypto (PQC)

Kvantemaskiner: utrolig god på å regne ut ting!

pros and cons:

- cons: litt for god? **Asymmetrisk** avhenger at vi er dårlige på regne ut ting
- Pros: raskere beregeninger!



2.2 Postkvantekrypto

Hva betyr begrepet "postkvantekrypto"?
Poeng: 1 for riktig svar. 0 for feil svar, 0 for intet valg, maks 1, minimum 0.
Velg ett alternativ:

- Kryptoalgoritmer som ikke kan knekkes med kvantecomputere.
- Å benytte kvantecomputere til å knekke kryptoalgoritmer.
- Kryptoalgoritmer som kan knekkes med kvantekomputere.
- Kryptoalgoritmer som benytter kvantecomputere.

Maks poeng: 1

Til slutt:

5.4

5.4 Asymmetrisk kryptering

Hvilke nøkler benyttes i forbindelse med **asymmetrisk kryptering og dekryptering** av en hemmelig melding som skal sendes fra en avsender til en mottager?

Poeng: 0,5 for hver riktig, -0,5 for hver feil, 0 for ubesvart, 1 for alle riktig, minimum 0.

Velg ett eller flere alternativer

- ☐ Privat nøkkel til mottager
- ☐ Private nøkkel til avsender
- ☐ Offentlig nøkkel til avsender
- ☐ Offentlig nøkkel til mottager

Maks poeng: 1

Public Key Infrastructure

Men først, nøkler?

En nøkkel brukes til en enkelt anvendelse.

- Veldig omdiskutert ved definisjonen av *en nøkkel*.
- Anvendelse: En nøkkel tilhører én dør, ikke flere dører (ideelt…)

Relevant til faget: symmetriske nøkler, asymmetriske offentlige og -private nøkler

Svært eksamensrelevant med nøkler innen kryptografi

Eksempel

Ref. *Begreper er viktig!*



19 Nøkler

I denne oppgaven skal du flytte inn riktig begrep på riktig plass i teksten.
Poeng: 0,5 for riktig, -0,5 for feil, 0 for ubesvart, maks 3, minimum 0. Boksene kan gjenbrukes.

Hjelp

private	krypterer	hemmelige	verifiserer	offentlige	signerer

Bob [ ] en melding med Alice sin [ ] nøkkel. Deretter signerer han med sin [ ] nøkkel. og sender over meldingen. Alice [ ] signaturen med Bobs [ ] nøkkel, og dekrypterer meldingen med sin [ ] nøkkel.

Maks poeng: 3

Kryptoperiode

Tid en nøkkel er “aktiv” før den blir byttet ut

Består av:

- Beskyttelsesperioden
  - Gyldig tid for kryptering og signering av Dig.Sig
- Prosesseringsperioden
  - Gyldig tid for dekryptering og validering av Dig.Sig

Som regel, relativt kort.

- Motvirker HNDL-angrep /key-reuse
- gjør kryptoanalyse og brute-forcing vanskeligere, pga mindre tidsrom

17 **4.3 Kryptoperioder**

For hver periode, angi hvilken type nøkkel det gjelder. Poeng: 0,5 for hver korrekt, -0.5 for for hver feil, 0 for intet valg, maks 3, minimum 0.

Angi hvilken type nøkkel det gjelder

	hemmelig nøkkel	offentlig nøkkel	privat nøkkel
Beskyttelsesperiode for symmetrisk kryptering/dekryptering	○	○	○
Prosesseringsperiode for symmetrisk kryptering/dekryptering	○	○	○
Beskyttelsesperiode for asymmetrisk signatur/validering	○	○	○
Prosesseringsperiode for asymmetrisk signatur/validering	○	○	○
Beskyttelsesperiode for asymmetrisk kryptering/dekryptering	○	○	○
Prosesseringsperiode for asymmetrisk kryptering/dekryptering	○	○	○

Maks poeng: 3

Hemmelig nøkkel = symmetrisk
hemmelig nøkkel = shared secret

Hva er Public Key Infrastructure? (PKI)

Det er en infrastruktur bygget på troverdighet, som binder offentlige nøkler til identiteter.

- Grunnen til at Dig Sig fungerer
- *Hvordan vet jeg at denne offentlige nøkkelen egentlig tilhører Alice og ikke en angriper?*

Muliggjør distribuering av offentlige nøkkel gjennom sertifikater

- Skaper bedre autentisering av entiteter på internett

Format på offentlige nøkkel sertifikater er definert i X.509 standard

- Har vært eksamensspørsmål før

16 Nøkkelsertifikat 2

I denne oppgaven skal du skrive inn svaret, som skal være på formatet "-.---" (hvor du må erstatte hver "-" med en bokstav (stor eller liten bokstav spiller ingen rolle) eller et tall.
Poeng: 1 for riktig; 0 for feil eller ubesvart; maks 2; minimum 0.

Hva kalles standarden som brukes for public-key nøkkelsertifikater på Internett ?
Fyll in svaret her:

I dette kurset har vi nevnt en rekke asymmetriske kryptografi algoritmer som kan brukes til signering. For eksempel i en PKI-sammenheng.

Skriv **en, og bare en,** av disse algoritmene i forkortet form (eksempelvis ville kunstig intelligens vært KI) i feltet under:

Maks poeng: 2

Sertifikater

Signaturer utstedes av *Certificate Authority*, enten rot-CA eller mellomliggende.

- Mellomliggende har blitt gitt fullmakt på å gi signaturer på vegne av rot-CA

Prinsippet:

- nøkler distribueres sammen med digital signatur (signert av CA), som kan verifieres av den offentlige nøkkelen
  - kalles da et sertifikat

Rotsertifikatetet er forhåndslagret som en del av nettleseren

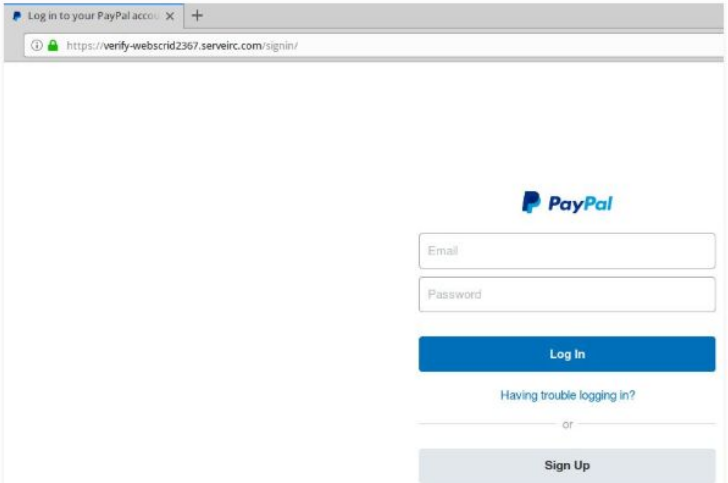
KrebsonSecurity
In-depth security news and investigation

HOME ABOUT THE AUTHOR ADVERTISING/SPEAKING

Half of all Phishing Sites Now Have the Padlock

November 26, 2018 98 Comments

Maybe you were once advised to "look for the padlock" as a means of telling legitimate e-commerce sites from phishing or malware traps. Unfortunately, this has never been more useless advice. New research indicates that half of all phishing scams are now hosted on Web sites whose Internet address includes the padlock and begins with "https://".



Bare fordi noe er HTTPS betyr ikke sikkert!

Usikre nettsider kan også ha legitime sertifikater. Det gir autentisitet, ikke pålitelighet.

X..509 standard

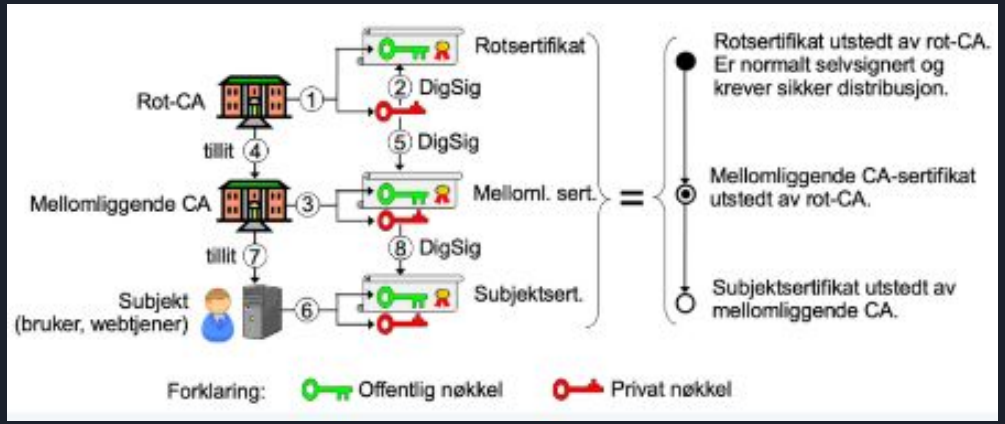
Formatet som forteller:

- Subject (hvem det tilhører)
- Issuer (hvem CA signerte den)
- Validity period
- Public key info
- Signature algorithm



Generering av sertifikat

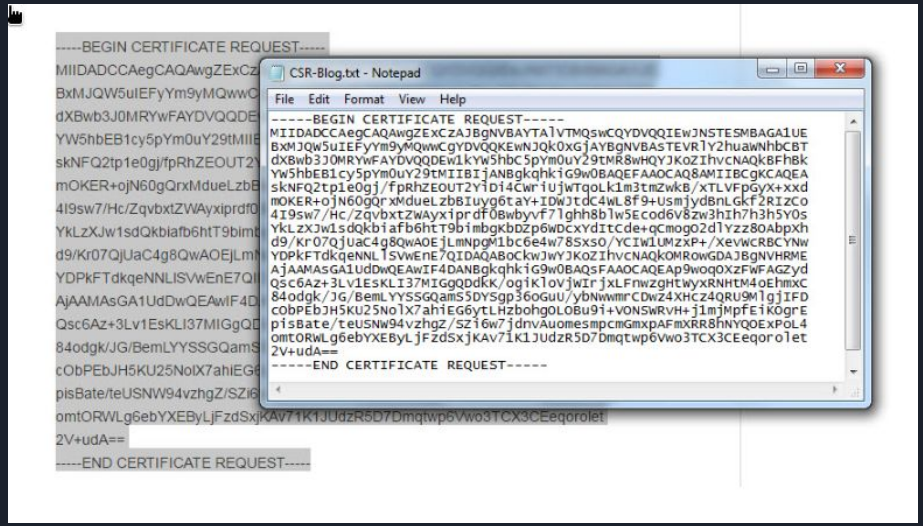
1. Samle alle datafeltene (Certificate Signing Request)
2. Subjekt hash'er dataskjemaet
3. signer hash-verdien
4. Legg den digitale signaturen til dataskjemaet



Certificate Signing Request (CSR)

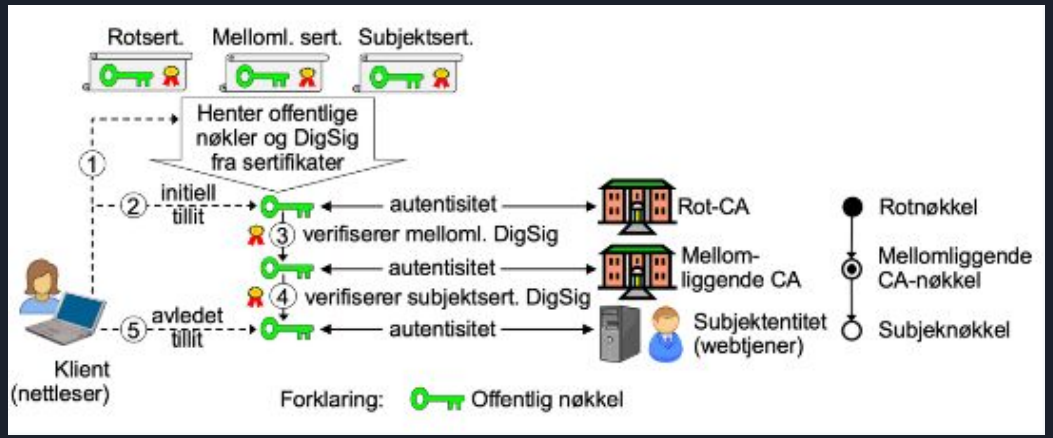
Inneholder:

- Subjekt identitet→ e.g. uio.no
- Subjektets offentlige nøkkel
- Subjektets egen signatur
  - (Beviser de har privat nøkkelen)
- Kan inneholde mer, men ikke like viktig å kunne.



Bare et eksmpel, ikke UiO sin!
Disse er private!

Validering av sertifikat



TL;DR: Initiell tillit (rot) → verifiser mellomliggende CA → verifiser subjekt → avledet tillit

1. Klienten (nettleseren) henter offentlige nøkler og DigSig fra alle tre sertifikatene (rot, mellomliggende, subjekt)
2. Klienten har initiell tillit til Rot-CA: rotsertifikatet er forhåndsinstallert i operativsystemet/nettleseren
3. Klienten verifiserer mellomliggende CA sitt sertifikat ved å sjekke Rot-CA sin DigSig med rotnøkkelen -> autentisitet bekreftet
4. Klienten verifiserer subjektsertifikatet (webserveren) ved å sjekke mellomliggende CA sin DigSig med mellomliggende CA-nøkkel → autentisitet bekreftet
5. Klienten har nå avledet tillit til subjektentiteten (webserveren) — tilliten er "arvet" nedover kjeden fra roten

CA-er og signering

Rot-CA:

- Signerer seg selv med privat nøkkel (Dig.Sig)
- Sertifikat med rot-CA sin offentlige nøkkel så signatur kan verifiseres

Mellomliggende CA:

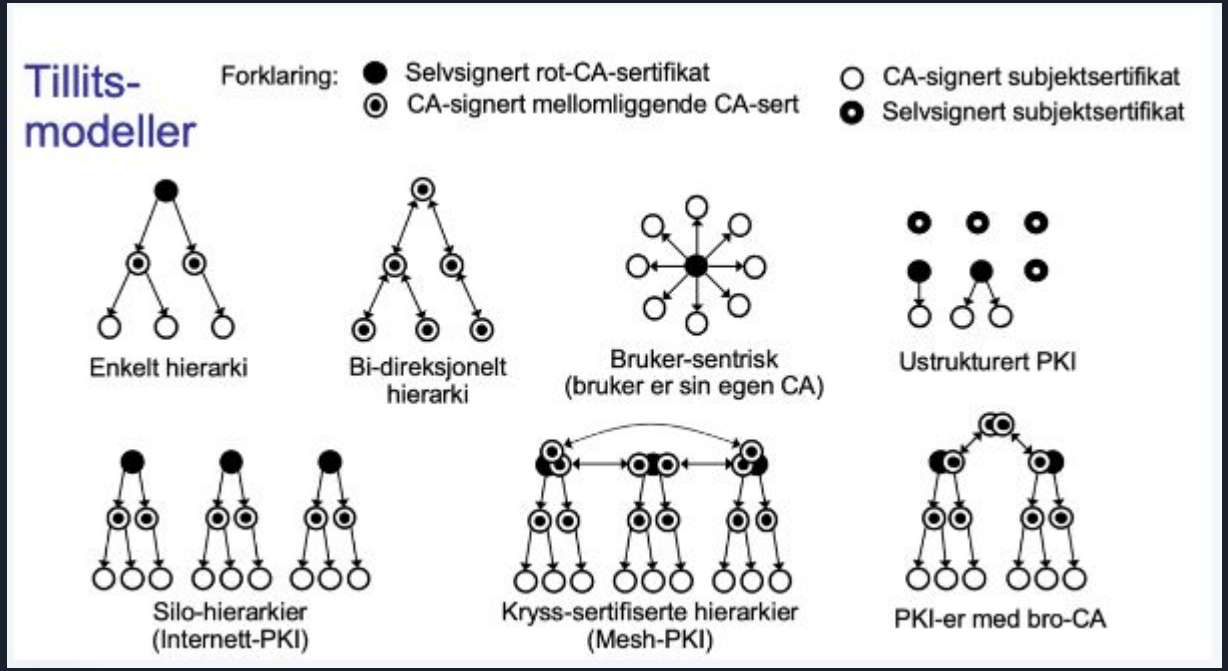
- Fullmakt: Signert av rot-CA(Dig.Sig)
  - Valideres med rot sin offentlige nøkkel
- Sertifikat med mellom-CA sin offentlige nøkkel

Subjektentitet/serversertifikat/webtjener

- **Ikke CA**
  - Signerer ikke sertifikater
- **Signert av mellom-CA (Dig.Sig)**
  - Valideres med mellom-CA sin offentlige nøkkel fra deres sertifikat
- Ha sitt eget sertifikat med sin egen offentlige nøkkel

CA-er og signering cont.

TL;DR: *Enkelt hierarki:* En rekke offentlige signaturer valideres i en lenke



15 Nøkkelsertifikat

Denne oppgaven omhandler nøkkelsertifikater og du må velge passende svar på nedtrekksmenyen.

Poeng: 1 for hvert riktig; -1 for gale svar, 0 for ubesvart; minimum 0.

Med din nettleser finner du følgende sertifikatsti for en nettside på inspera.no:



inspera.no er et eksempel på [Velg alternativ] (rot-CA, subjeksertifikat, mellomliggende CA).

Hvem har signert inspera.no? [Velg alternativ] (PKI, Rot CA, Mellomliggende CA, Selv-signert)

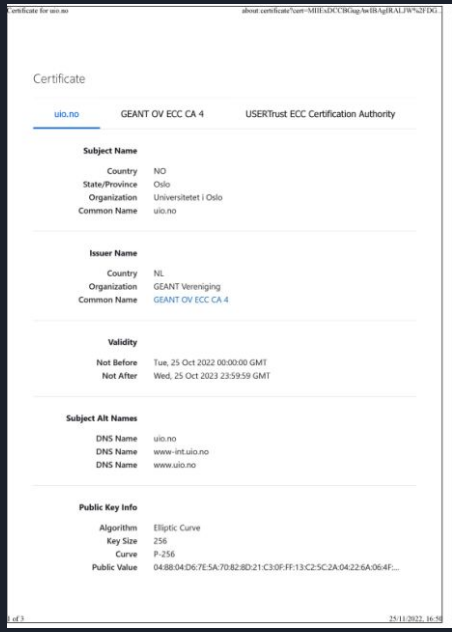
Maks poeng: 2

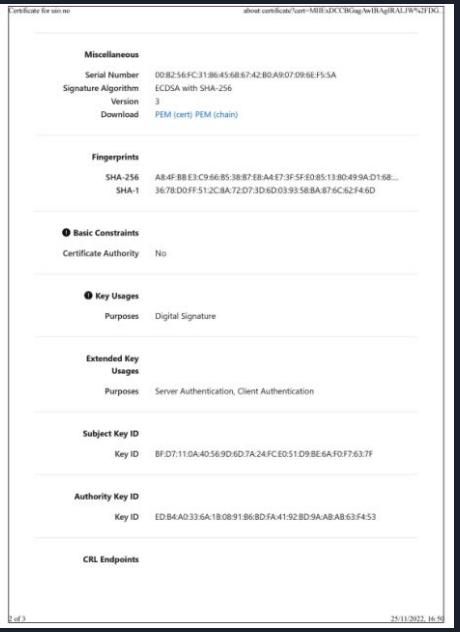
Bildet viser utdrag av tjener-sertifikatet for uio.no. Forstørr bildet for å gjøre det leselig (zoom inn og ut ved å trykke Ctrl + (pluss) og Ctrl – (minus). Bruk + og – tastene på det numeriske tastaturet).

Angi hvilke utsagn nedenfor som er korrekt vedrørende sertifikatet.
Poeng: 1 for hver riktig, -1 for hver feil, 0 for ubesvart, 2 for alle riktig, minimum 0.
Velg opp til 2 alternativer

- [ ] Sertifikatet inneholder tjenerens offentlige nøkkel.
- [ ] Sertifikatet kan brukes til å lage digital signatur.
- [ ] Sertifikatet kan brukes til å validere digital signatur.
- [ ] Sertifikated kan brukes til å dekryptere.
- [ ] Sertifikatet kan brukes til å kryptere.
- [ ] Sertifikatet inneholder tjenerens private nøkkel.

Maks poeng: 2





6.3

6.3 PKI og tillit

Angi 4 korrekte utsagn om PKI og tillit.
Poeng: 0,5 for hver riktig, -0,5 for hver feil, 0 for ubesvart, 2 for alle riktig, minimum 0.
Velg ett eller flere alternativer

- [ ] PKI gjør det mulig å utveksle private nøkler mellom klient og server.
- [ ] Tillitsmodellen for internett-PKI har flere enn bare én rot-CA.
- [ ] Et server-sertifikat gir en garanti for at nettsidens domenenavn er autentisk.
- [ ] En CA sjekker identiteten til eieren av et domene før det utstedes serversertifikat for domenet.
- [ ] Korrekt validering av et server-sertifikat gir en garanti for at nettsiden er pålitelig.
- [ ] Server-sertifikater gjør det mulig for klient å autentisere tjener ved opprettelse av en øktnøkkel.
- [ ] Server-sertifikater gjør det umulig å spoofe nettsider.
- [ ] Selv-signering av rot-sertifikater gir en garanti for at rot-sertifikatet er autentisk.

Maks poeng: 2